Relazione Progetto OSINT: Analisi del dominio spotify.com

1. Introduzione

L’obiettivo di questa esercitazione consisteva nel raccogliere informazioni in modalità passiva da fonti aperte e analizzarle con l'ausilio di script Python e intelligenza artificiale.

Per raggiungere questo scopo, è stato utilizzato:

- L'automazione tramite uno **script Python** per l'estrazione di dati tecnici
- L'utilizzo delle **Google Dorks** per individuare documenti o directory esposti

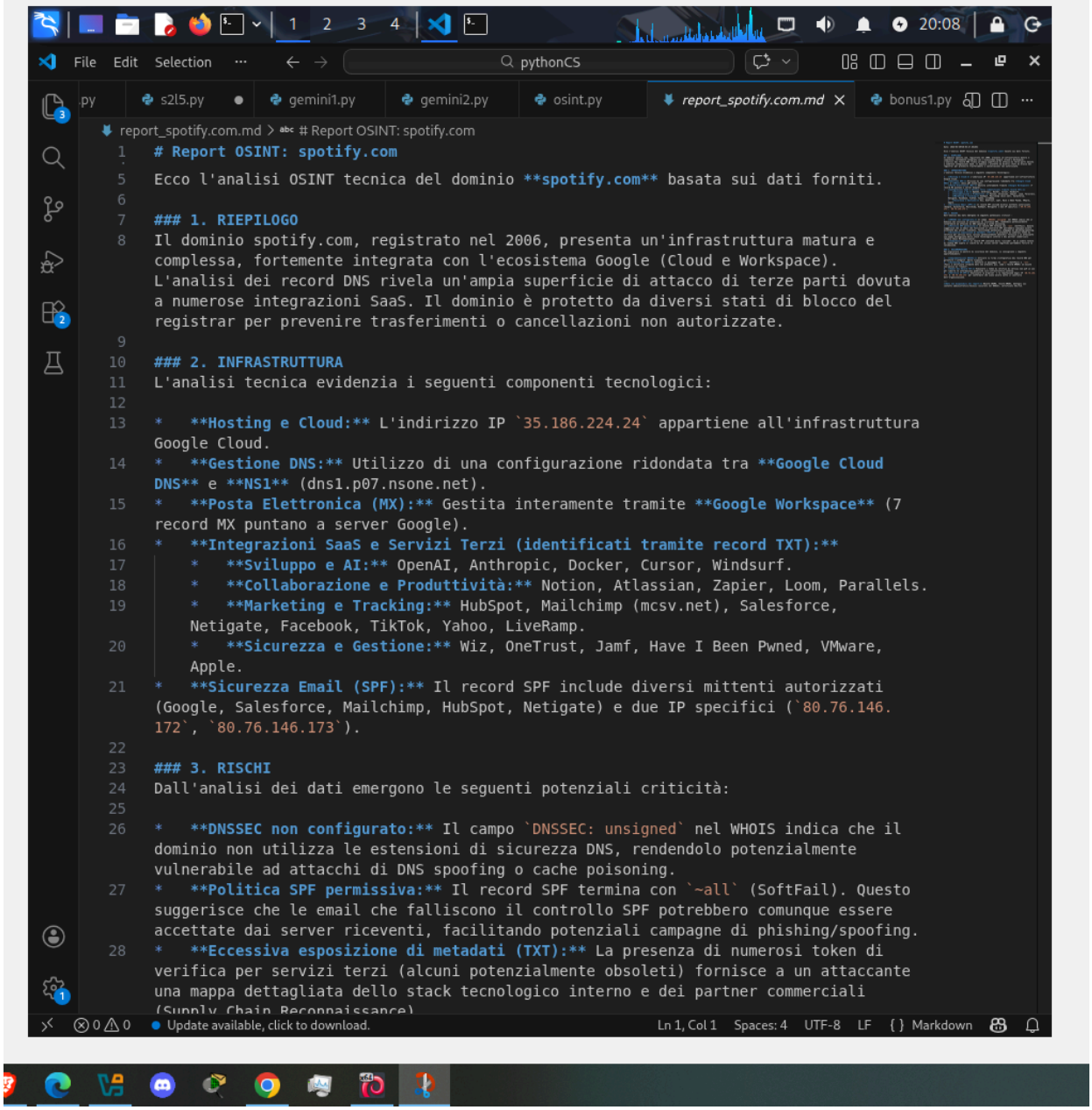
2. Analisi tecnica con Python (`osint.py`)

Per analizzare i dati tecnici necessari, ho utilizzato lo script `osint.py`.

Lo script interroga automaticamente i record DNS e i database WHOIS, fornendo poi i dati grezzi a un modello di intelligenza artificiale (è stato possible tramite API Gemini) che li trasforma in un report.

Esecuzione nel terminale: Una volta predisposto l'ambiente di lavoro su Kali Linux, ho eseguito lo script. Come si osserva dallo screenshot: lo script ha seguito una pipeline precisa: ha contattato i server per i record DNS e WHOIS, ha salvato i dati in formato JSON per l'archiviazione e ha infine generatoil report descrittivo.

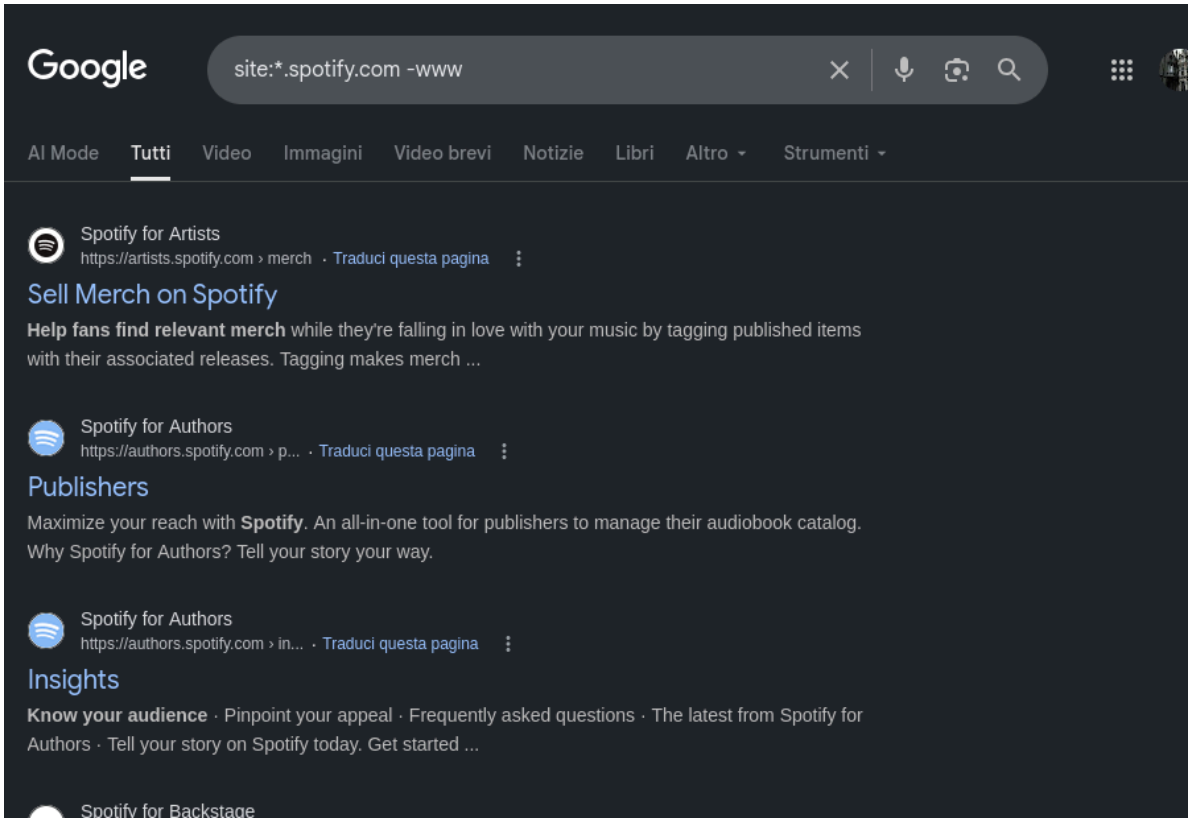
```
┌──(venv)─(kali㉿kali)-[~/Documents/pythonCS]
└─$ python3 osint.py spotify.com
[*] Pipeline OSINT per: spotify.com
[*] Timestamp: 2026-03-30T20:03:07.042306

[+] Fase 1: Raccolta DNS ...
[+] Fase 1: Raccolta WHOIS ...
[+] Fase 2: Organizzazione dati ...
[+] Dati salvati in osint_spotify.com.json
[+] Fase 3: Analisi con AI ...
[+] Report salvato in report_spotify.com.md

================================================
Ecco l'analisi OSINT tecnica del dominio **spotify.com** basata sui dati forniti.

### 1. RIEPILOGO
Il dominio spotify.com, registrato nel 2006, presenta un'infrastruttura matura e complessa, fortemente integrata co
n l'ecosistema Google (Cloud e Workspace). L'analisi dei record DNS rivela un'ampia superficie di attacco di terze
parti dovuta a numerose integrazioni SaaS. Il dominio è protetto da diversi stati di blocco del registrar per preve
nire trasferimenti o cancellazioni non autorizzate.

### 2. INFRASTRUTTURA
L'analisi tecnica evidenzia i seguenti componenti tecnologici:

*   **Hosting e Cloud:** L'indirizzo IP `35.186.224.24` appartiene all'infrastruttura Google Cloud.
*   **Gestione DNS:** Utilizzo di una configurazione ridondata tra **Google Cloud DNS** e **NS1** (dns1.p07.nsone.n
et).
*   **Posta Elettronica (MX):** Gestita interamente tramite **Google Workspace** (7 record MX puntano a server Goog
le).
*   **Integrazioni SaaS e Servizi Terzi (identificati tramite record TXT):**
    *   **Sviluppo e AI:** OpenAI, Anthropic, Docker, Cursor, Windsurf.
    *   **Collaborazione e Produttività:** Notion, Atlassian, Zapier, Loom, Parallels.
    *   **Marketing e Tracking:** HubSpot, Mailchimp (mcsv.net), Salesforce, Netigate, Facebook, TikTok, Yahoo, Liv
eRamp.
    *   **Sicurezza e Gestione:** Wiz, OneTrust, Jamf, Have I Been Pwned, VMware, Apple.
*   **Sicurezza Email (SPF):** Il record SPF include diversi mittenti autorizzati (Google, Salesforce, Mailchimp, H
ubSpot, Netigate) e due IP specifici (`80.76.146.172`, `80.76.146.173`).

### 3. RISCHI
Dall'analisi dei dati emergono le seguenti potenziali criticità:

*   **DNSSEC non configurato:** Il campo `DNSSEC: unsigned` nel WHOIS indica che il dominio non utilizza le estensi
oni di sicurezza DNS, rendendolo potenzialmente vulnerabile ad attacchi di DNS spoofing o cache poisoning.
*   **Politica SPF permissiva:** Il record SPF termina con `~all` (SoftFail). Questo suggerisce che le email che fa
lliscono il controllo SPF potrebbero comunque essere accettate dai server riceventi, facilitando potenziali campagn
e di phishing/spoofing.
*   **Eccessiva esposizione di metadati (TXT):** La presenza di numerosi token di verifica per servizi terzi (alcun
i potenzialmente obsoleti) fornisce a un attaccante una mappa dettagliata dello stack tecnologico interno e dei par
tner commerciali (Supply Chain Reconnaissance).
*   **Complessità SPF:** Il record SPF contiene molti "include". Se il numero totale di lookup DNS supera il limite
 di 10, alcuni server legittimi potrebbero fallire la validazione.
```



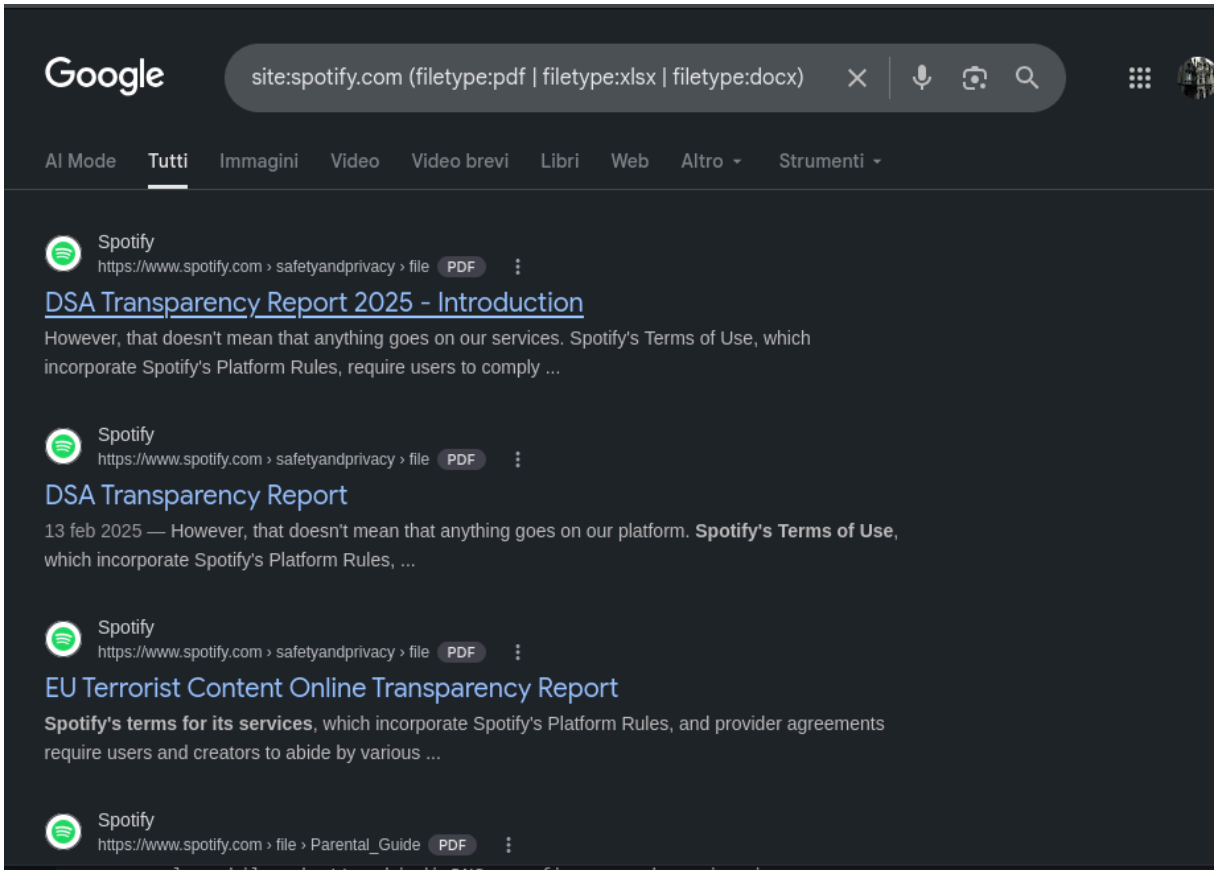
3. Esplorazione tramite Google Dorking

In seguito ho approfondito l'analisi utilizzando le tecniche di Google Dorking.

Trovare i sottodomini: Utilizzando la dork `site:*.spotify.com -www`



Ricerca di documenti sensibili: Ho utilizzato una dork: `site:spotify.com (filetype:pdf | filetype:xlsx | filetype:docx)`.



4. Conclusione

L'analisi svolta mi ha permesso di osservare concretamente come le informazioni di un'azienda sono distribuite e quanto l'analisi OSINT e le DORKs siano fondamentali.

Nello specifico:

- **Efficacia dello script Python:** L'automazione è stata fondamentale per ottenere un elenco di dati tecnici puliti e già organizzati. L'integrazione con l'intelligenza artificiale ha permesso di trasformare dati grezzi in un report leggibile.
- **Valore del Google Dorking:** L'uso delle dorks ha permesso di esplorare aspetti del sito non visibili con una ricerca normale.